

Literatür Notları (SLR — Hafta 1-2 Çıktısı)

Tor FSM Invalid State Transition Detection — 20 Birincil Kaynak

Öğrenci: Nurcan Denli Bayır (N25110987) | **Ders:** BYZ 658 — Yazılım Test Teknikleri |

Danışman: Nebi Yılmaz

Üniversite: Hacettepe Üniversitesi | **Tarih:** 14.05.2026

Özet. Bu doküman, tezin Hafta 1-2 sistematik literatür taraması çıktısının yoğunlaştırılmış halidir. 20 birincil kaynak beş tematik kümeye ayrılmıştır:

- **A.** Tor Güvenliği ve Anonimlik (6 kaynak) — Tor'a özgü saldırılar ve protokol tanımı.
- **B.** FSM Tabanlı Test ve Model Öğrenme (5 kaynak) — Metodolojik temel.
- **C.** Formal Yöntemler ve Protokol Doğrulama (3 kaynak) — Tehdit modeli ve doğrulama tekniği.
- **D.** Yazılım Testi Metodolojisi ve SLR (3 kaynak) — Süreç kılavuzu.
- **E.** Tor Simülasyonu ve Deneysel Altyapı (3 kaynak) — Doğrulama ortamı.

Her girdi: tam atıf + tezle ilişkilendirilmiş 1 paragraf yorumdan oluşur. Atıf formatı IEEE/APA karması olup tez yazımında IEEE'ye göre yeknesaklaştırılacaktır.

A. Tor Güvenliği ve Anonimlik

[1] Dingedine, R., Mathewson, N., Syverson, P. (2004). *Tor: The Second-Generation Onion Router. USENIX Security Symposium.*

Tor protokolünün ilk akademik tanımlaması. Devre kurulum (CREATE/CREATED, EXTEND/EXTENDED), yönlendirme katmanı (onion routing) ve threat model burada tanıtılır. Tezimiz için bu makale 8 tablosunun referans temelidir; özellikle 4.2 numaralı bölümdeki 'building circuits' alt başlığı, mevcut FSM tasarımındaki IDLE → CONNECTING → ... → CIRCUIT_READY zincirinin spec-uyum çerçevesini verir.

[2] Murdoch, S. J., Danezis, G. (2005). *Low-Cost Traffic Analysis of Tor*. *IEEE Symposium on Security and Privacy*.

Tor'a karşı yapılan ilk ucuz trafik korelasyon saldırısının analizi. Bu çalışma, anonimliği bozan saldırıların yalnızca kriptografik düzeyde değil, ağ-katmanı davranış imzaları üzerinden de mümkün olduğunu kanıtlar. Tezimizin 'state-level zafiyet' tezini neden tamamlayıcı bir eksen olduğunun gerekçesini sağlar.

[3] Johnson, A., Wacek, C., Jansen, R., Sherr, M., Syverson, P. (2013). *Users Get Routed: Traffic Correlation on Tor by Realistic Adversaries*. *ACM CCS*.

Realistik saldırgan modelleri altında trafik korelasyonunun anonimlik üzerindeki etkisini ölçer. Bizim tehdit modelimizdeki 'pasif on-path' saldırgan tanımı bu çalışmadan ödünç alınmıştır; ancak bizim çalışmamız korelasyonu kapsam dışı tutar ve state-uyumunu hedefler.

[4] Panchenko, A., Lanze, F., Zinnen, A., Henze, M., Pennekamp, J., Wehrle, K., Engel, T. (2016). *Website Fingerprinting at Internet Scale*. *NDSS*.

İnternet ölçeğinde website fingerprinting saldırılarının uygulanabilirliğini ölçer. Tezimiz açısından önemli olan: bu saldırı, devre kurulum sırasının ('hücre dizisi') gözlemlenmesinden çıkarım yapar; bizim invalid-transition tespit motorumuz, bu tür diziye dayalı saldırıların izlerini algılayabilir.

[5] Karunanayake, I., Ahmed, N., Malaney, R., Islam, R., Jha, S. K. (2021). *De-Anonymisation Attacks on Tor: A Survey*. *IEEE Communications Surveys & Tutorials*, 23(4): 2324-2350.

Tor'a karşı yapılan deanonymization saldırılarının kapsamlı bir taraması. Yedi saldırı kategorisi tanımlar; bizim Ek B'deki yedi saldırı vektörümüzün dördü (Replay, Hijack, Bypass, Ghost) bu sınıflandırmadan türetilmiştir. SLR sürecinin en güçlü kaynak makalesidir.

[6] Backes, M., Kate, A., Manoharan, P., Meiser, S., Mohammadi, E. (2013). *AnoA: A Framework for Analyzing Anonymous Communication Protocols*. *IEEE CSF*.

Anonim iletişim protokollerinin formal analizi için genel bir çerçeve sunar. AnoA, bizim FSM tabanlı yaklaşımımızla doğrudan rakip değil tamamlayıcıdır: AnoA olasılıksal anonimlik garantilerine, biz state-uyum garantilerine bakıyoruz.

B. FSM Tabanlı Test ve Model Öğrenme

[7] Lee, D., Yannakakis, M. (1996). *Principles and Methods of Testing Finite State Machines—A Survey. Proceedings of the IEEE, 84(8): 1090–1123.*

FSM tabanlı test üretimi için klasik referans. W-method, Wp-method ve UIO sequences gibi tekniklerin tanımı buradan gelir. Bizim BFS-tabanlı pozitif test üreticimiz, transition coverage maksimizasyonu için bu makaledeki 'transition tour' fikrinin sadeleştirilmiş bir versiyonudur.

[8] Tretmans, J. (2008). *Model Based Testing with Labelled Transition Systems. Formal Methods and Testing, LNCS 4949: 1–38.*

Etiketlenmiş Geçiş Sistemleri (LTS) üzerinden model-tabanlı test üretiminin teorik temeli. Bizim 'oracle' kavramımız, Tretmans'ın 'ioco' uyum bağıntısının basitleştirilmiş versiyonudur (FSM deterministik olduğu için).

[9] de Ruiter, J., Poll, E. (2015). *Protocol State Fuzzing of TLS Implementations. USENIX Security.*

TLS implementasyonlarında protokol state fuzzing'in pratik bir uygulaması. Bizim çalışmamızla aynı metodoloji ailesinden: gerçek implementasyondan FSM çıkar, ardından geçersiz geçişleri test et. Tor için bu işin daha önce yapılmamış olması, tezimizin literatür boşluğu argümanını destekler.

[10] Fiterău-Broștean, P., Janssen, R., Vaandrager, F. (2016). *Combining Model Learning and Model Checking to Analyze TCP Implementations. CAV.*

TCP implementasyonlarından FSM otomatik öğrenme ve model checking ile birleştirme. Tezin gelecek çalışma bölümünde belirtilebilecek bir genişleme yönü: bizim manuel olarak tanımladığımız δ , model öğrenme (L^*) ile gerçek bir Tor implementasyonundan çıkartılabilir.

[11] Ammann, P., Offutt, J. (2016). *Introduction to Software Testing (2nd ed.). Cambridge University Press.*

Yazılım testinin standart ders kitabı. Bölüm 7 (Graph Coverage) bizim transition coverage metriğimizin formal tanımını verir; node coverage = state coverage, edge coverage = transition coverage karşılığı kurulur.

C. Formal Yöntemler ve Protokol Doğrulama

[12] Dolev, D., Yao, A. C. (1983). *On the Security of Public Key Protocols. IEEE Transactions on Information Theory, 29(2): 198-208.*

Klasik 'Dolev-Yao' saldırgan modeli. Tezimizin tehdit modeli bölümü, bu modelin sınırlı bir alt kümesini benimser: ağ üzerinde mesaj gözlemleme/geciktirme/replay yapabilen ama imzalanmış mesajları sahteleyemeyen aktif on-path saldırgan.

[13] Bhargavan, K., Blanchet, B., Kobeissi, N. (2017). *Verified Models and Reference Implementations for the TLS 1.3 Standard Candidate. IEEE S&P.*

TLS 1.3 spesifikasyonunun ProVerif ile formal doğrulaması. Tezimizin formal modelleme bölümünü destekleyen 'state machine doğrulanabilir' tezinin pratik kanıtı. Tor TLS katmanı, ntor el-sıkışma sonrası değil-önce — bu makaleyle aynı disiplinde.

[14] Somorovsky, J. (2016). *Systematic Fuzzing and Testing of TLS Libraries. ACM CCS.*

TLS kütüphanelerinde sistematik fuzzing. Bizim 'negatif test üretimi' fikrinin yakın akrabası: spec-dışı mesajlar göndererek implementasyonun nasıl tepki verdiğini ölçer. Tor için bunu state-level yapmak bizim katkımızdır.

D. Yazılım Testi Metodolojisi ve SLR

[15] Felderer, M., Büchler, M., Johns, M., Brucker, A., Breu, R., Pretschner, A. (2016). *Security Testing: A Survey. Advances in Computers, 101: 1-51.*

Güvenlik testi tekniklerinin geniş kapsamlı taraması. Risk-driven security testing, threat modeling, model-based security testing ana başlıklarını verir. Bizim çalışmamız 'Model-Based Security Testing of State Machines' alt kategorisine düşer.

[16] Pretschner, A., Mouelhi, T., Le Traon, Y. (2008). *Model-Based Tests for Access Control Policies. ICST.*

Erişim kontrol politikaları için model-tabanlı test üretiminin erken örneklerinden biri. Bizim için önemli olan metodoloji aktarımı: politika ihlalleri (negatif testler) sistemli şekilde nasıl üretilir.

[17] Kitchenham, B., Charters, S. (2007). *Guidelines for performing Systematic Literature Reviews in Software Engineering*. EBSE Technical Report EBSE-2007-01.

SLR metodolojisinin standart kılavuzu. Tezimizin Hafta 1-2 SLR adımı PRISMA + Kitchenham yönergesini izleyecek; veritabanı seçimi, dahil-hariç tutma kriterleri, kalite değerlendirme bu kaynaktan türetilir.

E. Tor Simülasyonu ve Deneysel Altyapı

[18] Jansen, R., Bauer, K., Hopper, N., Dingledine, R. (2012). *Methodically Modeling the Tor Network*. USENIX CSET.

Tor ağının deneysel olarak modellenmesi için Shadow simülatörünün ilk kullanımları. Tezimizin Ground Truth stratejisinin Katman 3'ünde Shadow üzerinde küçük topoloji kurarak FPR ölçümü yapılması bu makalede önerilen yaklaşıma dayanır.

[19] Tor Project. (2026). *Tor Protocol Specification (tor-spec)*. <https://spec.torproject.org/tor-spec>, son erişim: Şubat 2026.

Tor protokolünün resmi yaşayan spesifikasyonu. 6 tablosunun otorite kaynağı; hücre formatları, devre kurulum sırası, RELAY hücrelerinin geçerlilik koşulları burada tanımlıdır. SLR'de literatür ile spec arasındaki uyumsuzluklar açıkça belgelenecektir.

[20] Microsoft Research. (2018). *A Data-Driven FSM Model for Analyzing Security Vulnerabilities*. Microsoft Research Technical Report.

Veriden FSM çıkarıp güvenlik analizi yapan endüstriyel bir örnek. Tezimizin 'state-level analiz' tezini güçlendiren pratik bir referans; ancak bu çalışma Tor'a özel değildir. Tor için ilk sistematik uygulamayı bizim yapıyor olmamız literatür boşluğunu doğrular.

Literatür Boşluğu — SLR Sonucu

20 kaynağın incelenmesi sonucu net şekilde gözlemlenen boşluk:

- **Tor'a özgü FSM modeli (kaynak 1, 19):** spesifikasyon var, ancak *formal 5-tuple FSM* olarak akademik literatürde derlenmiş bir kaynak yok.
- **Protokol state fuzzing (kaynak 9, 14):** TLS için yapılmış, Tor için yapılmamıştır.

- **Saldırı vektörü ↔ state geçişi eşleme (kaynak 5):** kategorik sınıflandırma var, fakat her saldırının imzasını bir δ -dışı (state, event) çiftiyle eşleyen *satır-satır tablo* mevcut değil.
- **ITDR metriği:** "tespit edilen geçersiz geçişler / enjekte edilenler" oranını Tor'da ölçen birincil çalışma yok.

Bu dört boşluk birlikte tezimizin *katkı çerçevesini* oluşturur ve Bölüm 4 (Önem) argümanlarını destekler.